FRAUD READINESS · COMPREHENSIVE

Fraud Readiness Strategy and Control Blueprint

Fictional Retail Group (overstated confirmations)

Assessment reference FX-P6b

12 November 2026

Confidential. Prepared for the management of Fictional Retail Group (overstated confirmations).

Fictional prototype for MK review. The organisation is fictional, calculated figures are labelled test results, and this is not a customer report or a certified paid report.

EXECUTIVE DIAGNOSIS

The group reports a mature control environment, and its next task is to make that position one the board can rely on

On its own answers, the group has the core controls in place for 96 of the 106 fraud scenarios that apply to it, and a control reported as a gap in only four. Every core control is reported in place in fraud governance, in finance and banking, in customers and revenue, and in digital and identity fraud. Taken at face value, that is the profile of an organisation whose fraud programme has moved beyond policy into operation, with ownership, assessment, controls and response all described as working.

MK's reading of the answers is more cautious than the headline, for a reason the answers themselves supply. When a core control is reported in place, the method asks about the practices that make it work: the record it relies on, the list that defines its reach, the independence of the person who carries it out. In 15 scenarios those practices are reported weaker than the core control. In five more, the answers leave open how the control can work as described, and in one the answers about the same fact cannot both be true. The organisation has, in other words, described its controls more confidently than it has described the conditions they depend on.

This is a common and recoverable position. It usually arises when the core questions are answered by someone who knows the policy and the detailed questions by people who run the process, and it is resolved by asking the process owners how each control actually operates. It nevertheless matters, because fraud is rarely stopped by the existence of a control. It is stopped by a control that reaches every case, compares against something independent and is carried out by someone with no interest in the outcome, and those are exactly the conditions the weaker answers concern.

Three themes carry the diagnosis. The first is the gap between the answers and the practices behind them, which runs across every area. The second is that the fraud risk assessment, the process that should direct the controls, is where the answers are least consistent: it reports covering AI-enabled fraud while also reporting that it does not ask how AI could be used against high-risk processes, and it reports deciding a response to every risk above tolerance without a stated way of identifying those risks. The third is that no independent review examines procurement or payroll, which leaves the organisation dependent on the people who run those processes to describe them accurately.

The themes reinforce one another. An assessment that has not examined how controls could be defeated will not find the gap between a control's description and its operation, and without independent review nothing else will. The result is a position that may well be

accurate, but that the organisation cannot yet demonstrate to its board, its auditors or itself.

The fraud exposure that follows is specific. If the open answers resolve the weaker way, the group could pay invoices for goods it did not receive, lose stock that its counts would not reveal, allow an insider in a sensitive role to conceal a scheme, and act on an AI-generated instruction through a control that appears to work. None of these is a finding that the event has happened. Each is a route that the answers, as they stand, do not close.

Leadership's priorities follow from this. In the first thirty days, management should settle the AI answers and obtain written answers to the five open questions from the process owners. In the same period it should name the accountable executives and decide how procurement and payroll will be examined independently. Over the following two months it should put in place the four controls reported as gaps, together with monitoring of split orders, so that the pattern-level weaknesses in procurement are visible. By the end of the year each control should have met its success measure over a full cycle, and the board should be receiving a status report built on settled answers rather than on the original assessment.

The rest of this report sets out what the answers establish, what the organisation should build and how it should get there.

WHAT THE ASSESSMENT ESTABLISHES

CALCULATED TEST RESULT

87.8 of 100 TEST FIXTURE

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

UNRESOLVED INCONSISTENCIES

1 to settle; 5 to clarify

1 scenario has answers that cannot both be right. A further 5 scenarios raise questions the answers do not settle. Until they are settled, the controls concerned are not treated as covering their scenarios.

PROVISIONAL MANAGEMENT INTERPRETATION

4 with a control reported as a gap

On its own answers, the organisation reports the controls that stop the scenario in place for 102 of the 106 fraud scenarios that apply, of which 6 are unresolved or open to question, and a control reported as a gap in 4. This reads the organisation's own answers.

APPROVED READINESS CONCLUSION

None issued

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

SCOPE AND ANALYTICAL BASIS

This blueprint interprets the organisation's own answers and designs the response; it does not verify that controls operate

The analysis rests on answers given by the organisation's respondent and by the functions to which questions were referred, read against MK's fraud scenarios and controls. It covers 106 fraud scenarios across ten areas of the business, with no question left outstanding. MK has not examined documents, interviewed staff or tested any control. Where the report names a record, it is a record management should keep so that each control can be shown to work, not evidence MK has reviewed.

The value of the blueprint lies in what it does with the answers. It reads them together as well as one at a time, so that a control reported in place is compared with the practices that defend against the same scenario, using a reviewed table of relationships; 56 such comparisons were made here. It draws the individual answers into themes, traces how the weaknesses could combine into fraud, and designs the controls, operating model, decisions and programme that would close them.

Independent examination of whether the controls operate, through records, walkthroughs and testing, belongs to MK Advisory and is scoped and priced separately. The boundary matters for this organisation in particular, because the central question its answers raise is how its controls run in practice, which only that kind of examination, or the organisation's own process owners, can settle.

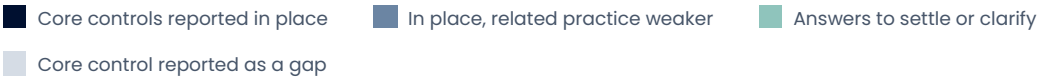
READINESS PROFILE

Four areas report every core control in place, and the doubts concentrate where the assessment directs the rest

The profile shows each area's fraud scenarios divided by what the answers report about the controls that stop them. The dark segments are scenarios whose core controls are reported in place; the tonal segments are those where a related practice is reported weaker; the sage segments are answers to settle or clarify; the pale segments are controls reported as gaps.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

AREA	SCENARIOS THAT APPLY	CORE CONTROLS IN PLACE	TEST FIGURE
Fraud governance and accountability		12 of 12	90.0
Fraud risk assessment		4 of 6	91.7
Ethics, integrity and anti-corruption		9 of 10	81.0
Third parties and supply chain		11 of 13	85.7
People, payroll and insider risk		9 of 11	89.1
Finance, banking and financial reporting		12 of 12	92.5
Customers, revenue and products		10 of 10	92.0
Assets, cash and inventory		8 of 10	82.0
Digital, cyber-enabled and identity fraud		14 of 14	87.1
Detection, speak-up and response		7 of 8	86.7



Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

The shape is that of an organisation with few outright gaps and a thin layer of doubt spread across most areas. In governance, finance, customers and digital, every core control is reported in place. In the remaining areas the doubts amount to a scenario or two each, but they recur, and in the fraud risk assessment they account for four of its six scenarios. That concentration matters more than its size suggests, because the risk assessment is the process through which management decides where every other control needs to be strongest.

SYSTEMIC THEMES

Three themes explain the position, and together they leave the answers without an independent check

Each theme below draws together answers from several scenarios and explains what the pattern means for how fraud would be prevented, detected or responded to. The map shows where each appears.

WHERE EACH THEME APPEARS

AREA	Controls reported in place rest on weaker practices than the answers suggest	The answers on fraud risk assessment do not yet support the position they report	Independent assurance examines high-risk processes
Fraud governance and accountability	●		
Fraud risk assessment	●	●	
Ethics, integrity and anti-corruption	●		
Third parties and supply chain	●		●
People, payroll and insider risk	●		●
Finance, banking and financial reporting	●		
Customers, revenue and products	●		
Assets, cash and inventory	●		
Digital, cyber-enabled and identity fraud	●		
Detection, speak-up and response	●		

A mark shows an area in which the answers contribute to the theme.

ACROSS THE ORGANISATION

The controls are described more fully than the practices that make them work

In 15 scenarios the core control is reported in place while a related practice is weaker, and in five more the answers raise a question they do not settle. The weaker practices are not peripheral. They include the record a count is compared with, the list that defines who must take block leave, the confirmation of receipt that an invoice is matched against, and the independence of whoever investigates a concern. Each is a condition the core control needs in order to work.

The pattern is consistent with answers given at two levels: the core questions by someone who knows what the policy requires, and the detailed questions by people closer to the process. That reading is an interpretation, but it fits every instance, and it points to a straightforward remedy. The process owners who gave the more cautious answers can say how each control runs, and their written answers will either confirm the position or correct it.

The implication for leadership is that the position should not yet be reported to the board as settled. Doing so would turn an unexamined description into a representation the board might rely on.

FRAUD RISK ASSESSMENT

The fraud risk assessment is least consistent exactly where it should direct the rest

The assessment reports covering AI-enabled schemes for every relevant process while also reporting that it does not ask how AI could be used against high-risk processes. It reports deciding a response for every risk above tolerance while reporting that risks are not rated for likelihood and harm. The area's other doubts are related practices reported weaker behind controls reported in place.

The fraud risk assessment is the organisation's instrument for deciding which scenarios need the strongest controls and for revising those controls as threats change. If it has not considered how AI could defeat controls that rely on recognising a voice, a face or a document, it will not have directed attention to the controls most exposed to that change. If it has no consistent way of identifying the risks that exceed tolerance, the decisions it records may follow familiarity rather than exposure.

Settling these two answers is therefore not a clerical correction. It determines whether the assessment can serve as the basis for the programme this report proposes, and it should be the fraud risk lead's first task.

No independent review examines procurement or payroll

Independent review of procurement and independent review of payroll are both reported weaker than in place, across third parties and supply chain and people, payroll and insider risk. These are the processes where most of the operational questions arise: how receipt is confirmed before invoices are paid, and how block leave reaches every sensitive role.

Independent review is the control that ordinarily catches the gap between how a process is described and how it runs. Its absence is what allows the first theme to persist, and the second theme means the risk assessment is unlikely to flag it.

The themes therefore form a closed loop: the answers are stronger than the practices, the assessment that should notice is itself uncertain, and nothing independent looks. Breaking the loop requires action on all three, and the programme in this report is sequenced to do that, settling the answers first, deciding on independent review in the same period and rebuilding the assessment's coverage of AI-enabled fraud.

FINDINGS

Seven findings show where the position depends on answers that are not yet settled

Six of the findings are scenarios whose answers must be settled or clarified, and the remaining one is the scenario in which the absence of independent review is most visible. They appear in the order of the method's areas, which is not a ranking. Each finding is read in the context of the controls around it. The full register of 25 findings is in the supporting workbook.

FRAUD RISK ASSESSMENT

The assessment cannot both cover AI-enabled fraud everywhere and leave high-risk processes unexamined

One answer reports that AI-enabled schemes, including deepfake instructions, synthetic identities and generated documents, are assessed for every relevant process; another reports that the assessment does not ask how AI could be used against high-risk processes. High-risk processes are among the relevant ones, so the two cannot both be true.

The related answers suggest which way the conflict may resolve. Testing controls against AI-generated fakes is reported as not in place, and including the organisation's own AI tools in scope and simulating an AI attack are reported as partly in place. If the assessment had examined AI-enabled attack on the high-risk processes, those practices would normally follow. The control-system consequence is significant, because several controls elsewhere rely on recognition: call-backs that rely on a known voice, onboarding checks that rely on documents, approvals that rely on a familiar instruction.

The target design matters because a control redesigned for AI-enabled attack verifies through a channel the attacker does not control rather than through recognition. Until the assessment has asked the question process by process, management cannot know which of its controls need that redesign.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
Answers that cannot both be right	AI-enabled fraud covered: in place	Fraud risk lead	30 days (proposed)

FRAUD RISK ASSESSMENT

Responses to risks above tolerance are reported without a stated way of identifying those risks

A response is reported as decided for every risk above tolerance, while likelihood and harm ratings are reported as not in place. Risks above tolerance can be identified without ratings, through a tolerance statement or a documented judgement, so the answers may be consistent; the question is how it is done.

The answer shapes everything that follows from the assessment. Where the identification of risks above tolerance is informal, the risks that receive a decided response tend to be the familiar ones, and controls, audit work and training are directed accordingly. The weaker related practices elsewhere in the area point the same way.

The fraud risk lead should document how risks above tolerance are identified today, so that management can decide whether that method is sufficient or whether the assessment needs a more consistent basis before it directs the programme.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Response decided: in place	Fraud risk lead	30 days (proposed)

THIRD PARTIES AND SUPPLY CHAIN

The invoice match may not rest on an independent record of what was received

Every invoice is reported as checked against an approved order and a confirmation of receipt before payment, while recording receipt of goods before payment is reported as partly in place and confirmation by the person who received a service as not in place.

A three-way match is only as strong as its third element. Where receipt is not written down, the match must rely on another confirmation, and if that confirmation comes from the person who requested the purchase, or from someone far from the work, it is not independent of the invoice. The answers do not say which applies. Approving orders before commitment is also reported as partly in place, which weakens the first element of the match as well.

This is the route by which overbilling and fictitious delivery are paid, and it interacts with the procurement-review gap: a supplier's inflated billing would pass each invoice check and would not be seen in aggregate either. The target is a match against a recorded receipt or a confirmed service, made by someone who did not approve the order.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Three-way match: in place	Finance lead	30 days (proposed)

PEOPLE, PAYROLL AND INSIDER RISK

Block leave is reported for every sensitive role, but no maintained list defines the roles

Block leave is reported as required for everyone in a sensitive role, while identifying high-risk roles on a maintained list is reported as partly in place. The requirement can reach every sensitive role without a list, so the answers need not conflict, but management has no way of showing that it does.

Block leave works by forcing someone else to do the work for long enough to expose a scheme that needs continuous attention. It fails quietly when it misses a role, and the roles most likely to be missed are those that have grown informally around one person. Separating conflicting duties during cover is reported as set out but not operating, so even where leave is taken, the person covering may hold duties that let the scheme continue.

The HR and payroll lead should establish how the requirement's reach is confirmed and, unless it can be shown another way, maintain the list of sensitive roles that block leave and cover arrangements depend on.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Block leave required: in place	HR and payroll lead	30 days (proposed)

ASSETS, CASH AND INVENTORY

Independent blind counts cannot reveal a loss without an expected quantity to compare with

Counts are reported as independent and blind to system quantities, while stock is reported as not formally recorded. A count reveals a loss only against an expected quantity, and the answers do not say what each count is compared with.

The related practices reported weaker are those that create and protect the expected quantity: restricting access to stores, issuing stock only against approved requests, separating custody from the records and explaining differences before adjusting. Together they suggest that the count may be well conducted and still unable to show a loss, because nothing reliable says what should be there.

This finding connects with the gap in loss tracking. Losses that are not tracked by location cannot be compared with what counts reveal, so a pattern of shrinkage at one site would not stand out. The finance lead should establish what the counts are compared with before they are described to the board as a control over stock loss.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Independent blind counts: in place	Finance lead	30 days (proposed)

DETECTION, SPEAK-UP AND RESPONSE

Investigations are reported as independent, but line management or HR conducts them

Every investigation is reported as independent of the area and people concerned, and suspected fraud as investigated by line management or HR. Both can be true if HR, or a manager from another area, investigates; the answers do not say whether a line manager ever investigates their own area.

The question matters for the whole response capability. An investigation conducted by someone close to the matter may not withstand a disciplinary hearing or a court, and concerns raised about a manager may be closed by that manager. The investigations lead should state whether line managers investigate their own areas and, where they do, how independence is secured.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Investigators independent: in place	Investigations lead	30 days (proposed)

THIRD PARTIES AND SUPPLY CHAIN

Supplier payments are reviewed only in some areas, so patterns across them can pass unseen

A senior review of supplier payments is reported in place only in some areas, cases or periods, monitoring of split orders is set out but not operating, reviewing payment data for unusual patterns is not in place, and independent review of procurement is partly in place.

These four answers describe the same capability from different angles: looking at payments as a population rather than one at a time. Without it, purchases split to avoid tender, duplicate invoices and payments to unfamiliar suppliers each pass their individual checks. It is the clearest instance of the independent-review theme and one of the four controls reported as gaps.

The target design combines a monthly senior review across every area with monitoring of split orders, each carried out by someone who does not process payments, so that the patterns individual checks cannot see become visible.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Senior review of supplier payments: partly in place	Finance lead	60 days (proposed)

FRAUD EXPOSURE AND PATHWAYS

If the open answers resolve the weaker way, four routes to loss remain open

The findings combine. Where an answer proves weaker than reported, one weakness can provide the opportunity and another delay its discovery. The pathways below illustrate how that could happen here. They are plausible sequences built from the answers and MK's scenario library, conditional on the answers resolving the weaker way, and they do not suggest that any event has occurred.

FRAUD PATHWAY · THIRD PARTIES AND SUPPLY CHAIN

A supplier invoices for more than it delivered, and the approval makes each payment look correct

A long-standing supplier begins to invoice for short deliveries, for partly performed services or at rates above those agreed, sometimes with an employee who approves its invoices sharing in the difference. The opportunity is an invoice check that rests on an approval rather than an independent record of receipt.

Each invoice is approved by someone who did not receive the goods or confirm the service and is paid in the normal run. Because it carries an approval, it looks properly processed, and because supplier payments are not reviewed as a whole in every area, nobody sees that the supplier's billing has drifted. The loss continues until a budget holder questions the spend or the relationship changes, by which time it may be difficult to quantify.

WARNING SIGNS

- Invoices without a matching receipt or delivery note
- Rates above the agreed contract
- Service invoices approved by people far from the work
- One approver for a supplier's invoices over a long period

FIRST RESPONSE

Hold payment on the suspect invoices, reconcile them to orders and receipts, and preserve the approval trail.

LASTING CONTROL

Every invoice is matched to an approved order and a recorded receipt or confirmed service before payment.

FRAUD PATHWAY · FRAUD RISK ASSESSMENT

A generated document or a cloned voice passes a control designed to recognise the real thing

An outsider uses readily available tools to imitate a senior person's voice, generate a convincing document or construct a synthetic identity, and presents it through the organisation's ordinary channels.

The control does what it was designed to do, but what it recognises is fake, so a payment, account or approval is granted on false grounds. If the risk assessment has not asked how AI could be used against each high-risk process, the controls concerned have not been tested or redesigned for this, and their records will show nothing wrong. The loss arises in exactly the controls management believes are effective.

WARNING SIGNS

- Requests that rely only on recognising a person or document
- Documents with flawless formatting from new counterparties
- Video or voice contact that avoids interaction
- Identity details that fit together too neatly

FIRST RESPONSE

Confirm the instruction or document with its source through a separate known channel, and suspend reliance on recognition-only checks in the process concerned.

LASTING CONTROL

The fraud risk assessment asks, for each high-risk process, how AI could be used against its controls, and controls that rely on recognition are tested and redesigned.

FRAUD PATHWAY · THIRD PARTIES AND SUPPLY CHAIN

A purchase is split below the approval limit, and nobody looks across the orders

A buyer who wants to avoid a tender splits a purchase into orders that each fall below the approval limit, or a supplier resubmits an invoice already paid with a changed number or date. Every transaction is within policy and passes its own checks.

The pattern exists only in the payment data, and without a monthly review in every area and working monitoring of split orders, nobody examines it. Purchases are made at uncompetitive prices, duplicate payments go unrecovered, and the loss grows with each payment run until a supplier, an auditor or a whistle-blower raises it.

WARNING SIGNS

- Several orders to one supplier just below an approval limit
- Invoices with the same amount and supplier close together
- A supplier paid more often than its contract suggests
- Orders raised and received by the same person

FIRST RESPONSE

Stop further payments on the suspect orders or invoices, recover any duplicate payment from the supplier, and preserve the order, approval and payment records.

LASTING CONTROL

A senior manager who does not process payments reviews each month’s supplier payments for splitting, duplicates, unfamiliar suppliers and changed bank details, and follows up each query.

FRAUD PATHWAY · PEOPLE, PAYROLL AND INSIDER RISK

An insider who never hands over their work sustains a scheme for years

A trusted employee in a sensitive role, such as creditors, payroll or stock, manipulates the records they control and keeps the scheme alive by being present for every transaction and every query that could expose it.

If the role was never identified as sensitive, block leave does not reach it; if cover is arranged with conflicting duties, the person covering cannot see the scheme either. The fraud needs continuous attention, which the employee gives, so it is usually discovered by chance and is large by the time it is found.

WARNING SIGNS

- An employee in a sensitive role who does not take leave
- Work that only one person understands or is allowed to do
- Queries that are always routed to the same person
- Resistance to rotation or process change

FIRST RESPONSE

Place the work with someone else immediately, review the period's transactions, and preserve the records before the employee is approached.

LASTING CONTROL

Sensitive roles are identified and recorded, and everyone in them takes block leave each year during which someone else does their work.

TARGET FRAUD-CONTROL ENVIRONMENT

The target environment closes the reported gaps and gives management a way to see patterns, not only transactions

The controls that close the four reported gaps, together with monitoring of split orders, form the core of the target environment. Each blueprint below explains the current position, how the control should operate and how management will know that it works; the specification panel summarises its operating design. The complete specification for every control the register acts on, 63 in all, including implementation activities, is in the supporting workbook. The controls behind the unresolved answers are deliberately not redesigned here, because their design depends on the answers.

CONTROL BLUEPRINT · TO PUT IN PLACE

A monthly senior review of supplier payments in every area

The review is reported in place only in some areas, cases or periods. In the target state, a senior manager who does not process payments reviews each month's supplier payments in every area for unfamiliar suppliers, unusual amounts, duplicates and changed bank details, and follows up each query to a recorded answer.

The review is the organisation's principal detective control over procurement, and it connects with the monitoring of split orders and with independent review of procurement: the review finds the anomaly, the monitoring finds the pattern, and independent review confirms that both run. Its first cycle should cover the previous twelve months, so that anything already in the data is followed up.

FRAUD SCENARIO IT ADDRESSES
Procurement anomalies are never noticed

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
Finance lead

POPULATION
Supplier payments

FREQUENCY
monthly

SERVICE LEVEL (PROPOSED)
Completed monthly; exceptions answered before the next review.

INDEPENDENT CHECK
Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT
Monthly payment review: the list reviewed, the reviewer, each query raised and its answer.

EFFECTIVENESS MEASURE
The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.

ESCALATION
Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE
Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

CONNECTED CONTROLS
Split orders monitored; Data reviewed for unusual patterns; Independent review of procurement

CONTROL BLUEPRINT · TO PUT IN PLACE

Link checks before any donation or sponsorship is committed

Checking recipients for links to officials, customers' decision-makers and employees is reported in place only in some cases. In the target state, every donation or sponsorship passes the check before money is committed, any link is disclosed and approved, and the approval file shows both.

The control is simple and preventive. Its value lies in reaching every commitment, which is why its measure is a complete approval file for each one, and why a commitment found without the check triggers a review of everything paid before it was found.

FRAUD SCENARIO IT ADDRESSES
Donations or sponsorships channel bribes

ACCOUNTABLE EXECUTIVE
Chief executive

PROCESS OWNER
Ethics lead

POPULATION
Donations and sponsorships

FREQUENCY
before each commitment

SERVICE LEVEL (PROPOSED)
Completed before each commitment; nothing proceeds while the check is open.

INDEPENDENT CHECK
A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT
Donation approval file: the recipient, the checks made, any link found and who approved the payment.

EFFECTIVENESS MEASURE
Every donation or sponsorship in the period has a donation approval file showing the link checks completed and approved before money was committed.

ESCALATION
Any item that proceeds without the check, or any exception approved, is reported to the chief executive within the month.

FAILURE RESPONSE
Where a donation or sponsorship went ahead without the check, complete the check at once and review anything paid or released before it was found.

CONTROL BLUEPRINT · TO PUT IN PLACE

Supervisor approval of hours and overtime before payment

Approval of hours by the employee's supervisor is reported in place only in some areas. In the target state, every timesheet is approved by the supervisor against the roster or attendance record before it is paid, and the system prevents the person who processes a timesheet from approving it.

The design places the check with the person who knows whether the work was done, and enforces segregation in the system rather than relying on instruction. A timesheet approved by the person who processed it is re-approved independently, and that person's other timesheets for the period are reviewed.

FRAUD SCENARIO IT ADDRESSES
Hours and overtime are inflated

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
HR and payroll lead

POPULATION
Timesheets

FREQUENCY
each pay run

SERVICE LEVEL (PROPOSED)
Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK
Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT
Timesheet approval record: each timesheet, the hours claimed, the supervisor's approval and the date.

EFFECTIVENESS MEASURE
Every timesheet paid in the period was approved by the employee's supervisor, against the roster or attendance record, before payment.

ESCALATION
Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.

FAILURE RESPONSE
Have any timesheet approved by the person who processed it re-approved independently, and review that person's other timesheets for the period.

CONTROL BLUEPRINT · TO PUT IN PLACE

Losses tracked by location and reported each month

Tracking losses of cash, stock and assets is reported in place only in some areas. In the target state, losses are tracked over time and by location and reported to management each month with the actions taken.

Loss tracking is the control that turns individual write-offs into a pattern. It also supports the stock finding: once losses are tracked by location, they can be compared with what the counts reveal, and a site where shrinkage concentrates becomes visible.

FRAUD SCENARIO IT ADDRESSES
Losses are never tracked

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
Finance lead

POPULATION
Losses of cash, stock and assets

FREQUENCY
monthly

SERVICE LEVEL (PROPOSED)
Completed monthly; exceptions answered before the next review.

INDEPENDENT CHECK
Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT
Loss report: losses by type and location over time, and the actions taken.

EFFECTIVENESS MEASURE
The review of losses of cash, stock and assets ran monthly throughout the period, and every exception it raised was reported to management with the action taken.

ESCALATION
Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE
Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

CONTROL BLUEPRINT · TO STRENGTHEN

Monitoring of split orders that actually runs

Monitoring of split orders is reported as set out but not yet operating. In the target state, orders to each supplier are reviewed each month for several smaller orders that together exceed an approval limit, by someone independent of the buyers, and each instance is followed up to a recorded conclusion.

Because the control is already designed, the work is to make it operate: to produce the report, name the reviewer and run the first review over the last twelve months. It complements the senior review of supplier payments, which looks at payments, by looking at the orders behind them.

FRAUD SCENARIO IT ADDRESSES
Procurement anomalies are never noticed

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
Procurement lead

POPULATION
Orders to the same supplier

FREQUENCY
monthly

SERVICE LEVEL (PROPOSED)
Completed monthly; exceptions answered before the next review.

INDEPENDENT CHECK
Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT
Split order report: orders grouped by supplier and period, each instance found and its conclusion.

EFFECTIVENESS MEASURE
The review of orders to the same supplier ran monthly throughout the period, and every exception it raised has a recorded conclusion.

ESCALATION
Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE
Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

CONNECTED CONTROLS
Senior review of supplier payments; Data reviewed for unusual patterns; Independent review of procurement

TARGET FRAUD-RISK OPERATING MODEL

Ownership already sits in the right places, and the operating model gives it a rhythm and an independent check

The organisation reports that executive accountability for fraud risk is written into a named executive's role and that the board holds final oversight. The target operating model builds on that. The chief executive remains accountable overall; the fraud risk lead coordinates the assessment, challenges the control owners and consolidates reporting; the owners of procurement, finance, payroll, ethics and investigations operate the controls in their processes and keep the records; and the investigations lead receives reports and alerts and investigates independently.

TARGET FRAUD-RISK OPERATING MODEL

OVERSIGHT **The board**	Receives fraud risk reporting, approves the order of work and holds the executive to account. The organisation's own answer on final oversight. STATUS AND ESCALATIONS REPORTED UPWARD · DIRECTION AND DECISIONS DOWNWARD
EXECUTIVE ACCOUNTABILITY **Chief executive**	Accountable for fraud risk overall; names the accountable executives and decides the order of work. Executive accountability is reported as "Yes, it is written into a named executive's role".
COORDINATION AND CHALLENGE **Fraud risk lead**	Coordinates the fraud risk assessment, challenges the control owners and consolidates status reporting. The method's owner for fraud risk assessment.
CONTROL OWNERSHIP **Finance lead, Ethics lead, HR and payroll lead, Procurement lead, Fraud risk lead and Investigations lead**	Operate the controls in their processes, keep the records and report exceptions. The method's owners for the controls this report acts on.
DETECTION AND INVESTIGATION **Investigations lead**	Receives reports and alerts, investigates independently and records outcomes. The method's owner for detection, speak-up and response.

Roles are named by function, not by person; the assessment does not identify individuals. The chief executive's coordinating role and the fraud risk lead's challenge role are the method's owners for governance and risk assessment.

What the model adds is a rhythm and an independent check. Status on each open scenario moves upward each month from the control owners to the fraud risk lead and on to the chief executive, and to the board at each meeting. Escalations follow the same route. The independent check is the decision the themes call for: how procurement and payroll will be examined by someone outside those processes, whether a manager from another area, internal audit or an external engagement.

LEADERSHIP DECISIONS

Four decisions rest with leadership, and the first determines how much of the rest can proceed

The decisions below are those only executives can take. For each, the options and trade-offs are set out with MK's recommended route; the choice remains management's.

LEADERSHIP DECISION

How the open answers will be settled

The six scenarios with answers to settle or clarify must be resolved before the controls concerned are relied on. The quickest route is for each process owner to establish how the process runs and correct the assessment; the most independent is an examination through MK Advisory. MK recommends starting with the process owners and bringing in an independent walkthrough only where an answer remains disputed, because most of the questions concern how the organisation's own processes run.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Process owners confirm and correct	Each process owner establishes how the process actually runs, records the answer and corrects the assessment where it was wrong.	Low: a few hours per process owner.	Fast, and keeps ownership with the people who run the processes.	Relies on the same people whose answers are in question.
Internal walkthrough by someone independent of the process	A manager from another area, or internal audit where it exists, walks through each process with its owner and records what was seen.	Moderate: a day or two per process.	An answer that does not rest only on the owner's view.	Takes longer and draws on people outside the process.
Independent validation through MK Advisory	MK examines the records and walks through the processes concerned, as a separately scoped engagement.	Higher: a scoped engagement.	An independent view of whether the controls operate, which the automated assessment cannot give.	Cost and time; worthwhile where the answers concern controls the organisation relies on heavily.

MK'S RECOMMENDED ROUTE

Process owners confirm and correct, with an independent walkthrough for any answer that is still disputed. The answers concern how the organisation's own processes run, which its owners can establish quickly; an independent view is needed only where that does not settle the question.

Decision owner: Chief executive. When: Before the controls concerned are relied on or reported as in place. If delayed: The organisation may rely on a control whose operation the answers do not establish.

LEADERSHIP DECISION

Who will be accountable for each open area

Six areas have an open or unresolved scenario. MK recommends that ownership stays with the executives who run those areas, with the fraud risk lead coordinating the requirements that span them, because the controls sit in the operating processes while several of the questions, such as independent review, cut across them.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
One accountable executive per area	Each area with open scenarios has one executive accountable for its controls, as the method suggests.	Low to decide; ongoing for each executive.	Clear ownership that matches how the organisation is run.	Requirements that span areas, such as how changes to payment details are verified, need coordination across owners.
One executive for the whole programme	A single executive owns every open scenario and directs area leads.	Concentrated on one person.	One point of accountability and a consistent approach.	Area executives may treat the work as someone else's.
Area owners with a programme coordinator	Area executives own their scenarios, and the fraud risk lead coordinates requirements that span areas and reports progress.	Moderate.	Ownership stays in the areas while cross-area requirements are handled once.	Needs a coordinator with enough standing to hold owners to account.

MK'S RECOMMENDED ROUTE

Area owners with a programme coordinator. The open scenarios sit in the operating areas, so ownership belongs there; several of the requirements span areas and are best designed once.

Decision owner: Chief executive. When: Before design work starts. If delayed: Open scenarios have no owner, and the controls that stop them stay unassigned.

LEADERSHIP DECISION

The order in which the open scenarios will be addressed

The order should rest on facts management can state and defend. MK recommends settling the answers first and then weighing each open scenario on how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much of the activity exists and what management knows of past incidents.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Explicit factors, settled facts first	Answers to settle come first; then each open scenario is weighed on how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much of the activity exists, and what management already knows of incidents.	Moderate: a structured management session.	A defensible order that management can explain to the oversight body.	Depends on information management must supply, such as volumes and known incidents.
Area by area	One area is completed before the next begins.	Low to plan.	Simple to manage and report.	Requirements that span areas are designed several times, and exposure in later areas waits.
Cross-area requirements first	Requirements that span areas, such as verifying changes to payment details, are designed once and applied everywhere, before area-specific controls.	Moderate.	One design closes several scenarios at once.	Area-specific exposures wait until the shared designs are complete.

MK'S RECOMMENDED ROUTE

Explicit factors, settled facts first, applying cross-area requirements once where they arise. An order of work should rest on facts management can state and defend to its oversight body, and designing shared requirements once avoids building the same control several times.

Decision owner: Chief executive. When: Before design work starts. If delayed: Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.

LEADERSHIP DECISION

How the board will see progress

MK recommends a one-page status for each open scenario at every board meeting until it is closed, deferred with a reason or accepted, because regular reporting keeps the programme moving once the first controls are in place.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
At each meeting of the oversight body	A one-page status per open scenario at each meeting until it is closed, deferred with a reason or accepted.	Low.	Keeps the scenarios visible to the people who can remove blockers.	Adds to the oversight body's agenda.
Quarterly summary	A consolidated summary each quarter.	Low.	Less frequent demand on the oversight body.	Blockers may wait a quarter before they are seen.
Exceptions only	Only scenarios that are late or blocked are reported.	Lowest.	Focuses attention on problems.	The oversight body does not see progress, and a scenario can drift without being reported as an exception.

MK'S RECOMMENDED ROUTE

At each meeting of the oversight body, until each open scenario is closed, deferred with a reason or accepted. Regular reporting is what keeps a programme moving once the first controls are in place.

Decision owner: Chief executive. When: From the first meeting after this report. If delayed: Progress is not visible until the next assessment.

TWELVE-MONTH IMPLEMENTATION BLUEPRINT

Over twelve months the programme moves from settled answers to controls that have proven themselves over a full cycle

The programme runs in four proposed stages. The windows are proposals for management's own plan, not deadlines, contractual dates or estimates of how long any control takes to design or to show that it works. A control counts as working only once it has met its success measure over a full operating cycle.

THE TWELVE-MONTH PROGRAMME, IN PROPOSED STAGES

Stabilise

0 TO 30 DAYS, PROPOSED

Settle the answers, name the owners and decide the order of work.

- Answers settled and questions answered
- Accountable executives named
- Order of work recorded with its factors

OWNERS

Fraud risk lead, Finance lead, HR and payroll lead, Investigations lead, Chief executive

Establish

31 TO 90 DAYS, PROPOSED

Approve the priority control designs, put them in place and run their first operating cycles.

- Senior review of supplier payments
- Recipients checked for links
- Hours approved by supervisor
- Losses tracked and reported
- Split orders monitored

OWNERS

Finance lead, Ethics lead, HR and payroll lead, Procurement lead

Embed

MONTHS 4 TO 6, PROPOSED

Extend to the remaining selected scenarios and strengthen the further defences, with regular reporting.

- Remaining selected controls put in place
- Related practices strengthened
- Monthly status reporting running

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Mature

MONTHS 7 TO 12, PROPOSED

Measure each control over a full cycle, refresh the scenarios and report to the oversight body.

- Each control measured over a full cycle
- Scenarios refreshed against the assessment
- Status reported to the board at each meeting

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

Stabilise is about facts and ownership: the AI answers settled, the open questions answered, the accountable executives named, the approach to independent review decided and the order of work set down with its factors. Establish puts the priority controls in place and runs their first cycles, beginning with the senior review of supplier payments and the monitoring of split orders, which can each look back over the previous twelve months as their first run.

Embed extends the work to the further defences behind the controls reported in place, the 57 related practices listed in the register, starting with those the settled answers show to matter. Mature measures each control over a full cycle, refreshes the scenarios against the corrected assessment and keeps the board informed at each meeting. Every action, with its deliverable and completion test, is in the supporting workbook.

MANAGEMENT FRAUD-READINESS SCORECARD

The scorecard tells management whether the controls work, not only whether they exist

Each control's measure describes what its records should show over a period once it operates; the programme measures track whether the response itself is moving. None is reported as met today. Escalation thresholds turn a missed measure into a decision rather than a note in a report.

MANAGEMENT FRAUD-READINESS SCORECARD

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.	Finance lead	monthly	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
Every donation or sponsorship in the period has a donation approval file showing the link checks completed and approved before money was committed.	Ethics lead	before each commitment	Any item that proceeds without the check, or any exception approved, is reported to the chief executive within the month.
Every timesheet paid in the period was approved by the employee's supervisor, against the roster or attendance record, before payment.	HR and payroll lead	each pay run	Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.
The review of losses of cash, stock and assets ran monthly throughout the period, and every exception it raised was reported to management with the action taken.	Finance lead	monthly	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
The review of orders to the same supplier ran monthly throughout the period, and every exception it raised has a recorded conclusion.	Procurement lead	monthly	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
Answers to settle and questions to clarify that have a written answer	Chief executive	each month until closed	Any item still open after the first 30 days is reported to the oversight body.
Open scenarios with a named owner and a recorded decision to address, defer or accept them	Chief executive	each month	A scenario without an owner after 60 days is reported to the oversight body.
Priority controls that have met their success measure for a full operating cycle	Fraud risk lead	each quarter	A control that misses its measure twice is reported with its owner's correction plan.
Status reported to the board	Chief executive	each meeting	A missed report is itself reported at the next meeting.

Control measures describe what each control's records should show for a period once it operates; programme measures track the response itself. None is reported as met today.

For this organisation the first measure to watch is the one on answers settled, because every other measure depends on it. The second is whether each priority control has met its measure over a full cycle, which is the point at which the board can treat a control as working rather than designed.

METHODOLOGY AND LIMITATIONS

The position rests on the organisation's own answers, read together against MK's method

Answers are read against MK's method of fraud scenarios and controls. A pair of answers is treated as a contradiction only where review has established that both describe the same fact and cannot both be true; where review found that both could be right, the report asks a question instead of concluding. Answers given as "not known" or declined would be reported as outstanding and never as weaknesses; none remained here.

The executive diagnosis states the position in four parts: the calculated result, the answers that are inconsistent, the reading of the answers and MK's conclusion. Material findings, blueprints and stages are chosen and sequenced by the rules stated where each appears, not by a ranking of fraud risk.

PROTOTYPE NOTICE: WHAT A RELEASED REPORT ADDS

ELEMENT	IN A RELEASED REPORT	IN THIS EDITION
Readiness conclusion	Issued under MK's approved readiness method, with the score and level that method defines.	Calculated result shown as a labelled test fixture; no level or band issued (decision D-1).
Order of work	Set by MK's approved decision method.	Ordered by the explicit factors stated in the report, a candidate method (decision D-3).
Control specifications, pathways and decision options	MK-approved advisory content.	Draft content from MK's control-content library, scenario structures and decision options (decision D-5).
Manuscript	Written by the production AI writer from this fact pack, then validated.	Written in-session under the same writer contract and validated by the same checks; the production AI run is a blocked acceptance test.

MANAGEMENT CONCLUSION

The group may already have the controls it reports, and a year from now it should be able to show it

The group's answers describe a mature fraud-control environment, and they may be right. What the assessment shows is that the organisation cannot yet demonstrate it: several controls are described more fully than the practices they depend on, the fraud risk assessment is uncertain on AI-enabled fraud and on how risks above tolerance are identified, and nothing independent examines procurement or payroll.

The transition required is from a described position to a demonstrated one. The foundations are settled answers, an independent check on the processes where the doubts concentrate, and a risk assessment that asks how controls could be defeated. On those foundations the four controls reported as gaps, and the monitoring of split orders, close the routes the answers leave open.

By ninety days, every open answer should be settled, every open area owned, the approach to independent review decided and the priority controls running their first cycles. By twelve months, each control should have met its measure over a full cycle, the assessment should have been refreshed on the corrected answers, and the board should be receiving a status report it can rely on.

MK Advisory would add value at two points: where an answer remains disputed after the process owners have responded, and once the programme is running, to examine whether the controls the organisation relies on most operate as designed. Both call for the evidence and walkthroughs that this assessment, by its nature, does not include.

MK FRAUD INSIGHTS

Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Fictional Retail Group (overstated confirmations) on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Fictional prototype for MK review; not a customer report.